

DO'S

&

DON'TS

Simple habits, massive security and uptime gains

Most breaches that flatten Indian startups and small offices can be traced to ten negligent habits – skipped training, un-patched routers, weak passwords, forgotten configs. Flip each habit into a repeatable ritual and you cut risk by orders of magnitude. We conclude with a few essentials you mustn't ignore, each expressed in plain language, then broken into a three-step action plan any lean IT team (or lone founder) can follow. Print the commandments as a wall poster or feed the steps into your favourite task manager.

01 Do 6-month drills on phishing, vishing & tailgating

Why it matters: Human error still triggers 82 % of breaches, and regulators and insurers now cite "bi-annual social-engineering training" as the SMB baseline.

Three-step drill

1. Run a 3-minute micro-module every six months (HIPAA Journal says twice-yearly beats annual by 40 % in click-rate reduction).
2. Follow with a simulated phish the next week; adjust difficulty monthly (SoSafe suggests 1–3 mails per month for reinforcement).
3. Reward reporting, not shaming – publicly thank the first person who flags a phish on Slack.

03 Do enforce MFA + password manager

Why it matters: NIST and CISA both rank MFA as the single most effective credential safeguard, slashing account-takeover risk by 99% overall.

Three-step drill

1. Enable MFA on email, VPN, payroll and admin portals first.
2. Issue a vault (Bitwarden, 1Password, etc.); pre-load shared secrets so no one ever emails a password again.
3. Disable password reuse checks in the vault; flag duplicates weekly.

02 Do patch OS, firmware and plugins inside 48 hours

Why it matters: FCC cyber-planner guidance lists "timely patching" as a core control, and recent FCC breach analyses peg the exploit-to-patch window at <72 h for SMB-class hardware.

Three-step drill

1. Turn on auto-update for Windows, macOS, browsers and plugins.
2. Schedule a weekly "patch sweep" Ansible/Intune job; treat switch & router firmware the same way (see Chapter 3).
3. Add a 48-hour SLA in your policy docs; measure with your NMS patch-compliance widget.

04 Don't rely on perimeter firewalls alone – embrace layered Zero Trust

Why it matters: Perimeter-only shops keep falling because attackers now pivot internally in minutes. Cisco's Zero-Trust guide calls "continuous verification inside the LAN" the new norm.

Three-step drill

1. Segment with VLANs and ACLs (see Chapter 2).
2. Deploy an identity-aware proxy (Cloudflare Zero Trust, Zscaler) for SaaS apps.
3. Feed firewall + proxy logs into one SIEM view; tune one set of alerts.